

Tema 71: La Ciberseguridad Aplicada al Cloud

Estrategias de Defensa, Normativas y el Modelo de Responsabilidad Compartida



La Seguridad en la Nube: Un Proceso Continuo

La ciberseguridad en el Cloud no es un producto; es el conjunto de políticas, controles, tecnologías y procedimientos para proteger datos, aplicaciones e infraestructura.



La Paradoja: El Cloud no es inseguro por naturaleza, pero introduce nuevos riesgos (multitenencia, acceso remoto, dependencia) que requieren una gestión específica.



Confidencialidad

Solo accede quien está autorizado.



Integridad

Los datos no se alteran indebidamente.

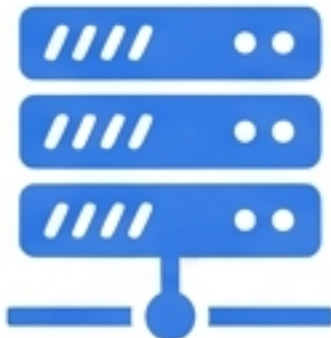


Disponibilidad

Acceso garantizado cuando se necesita.

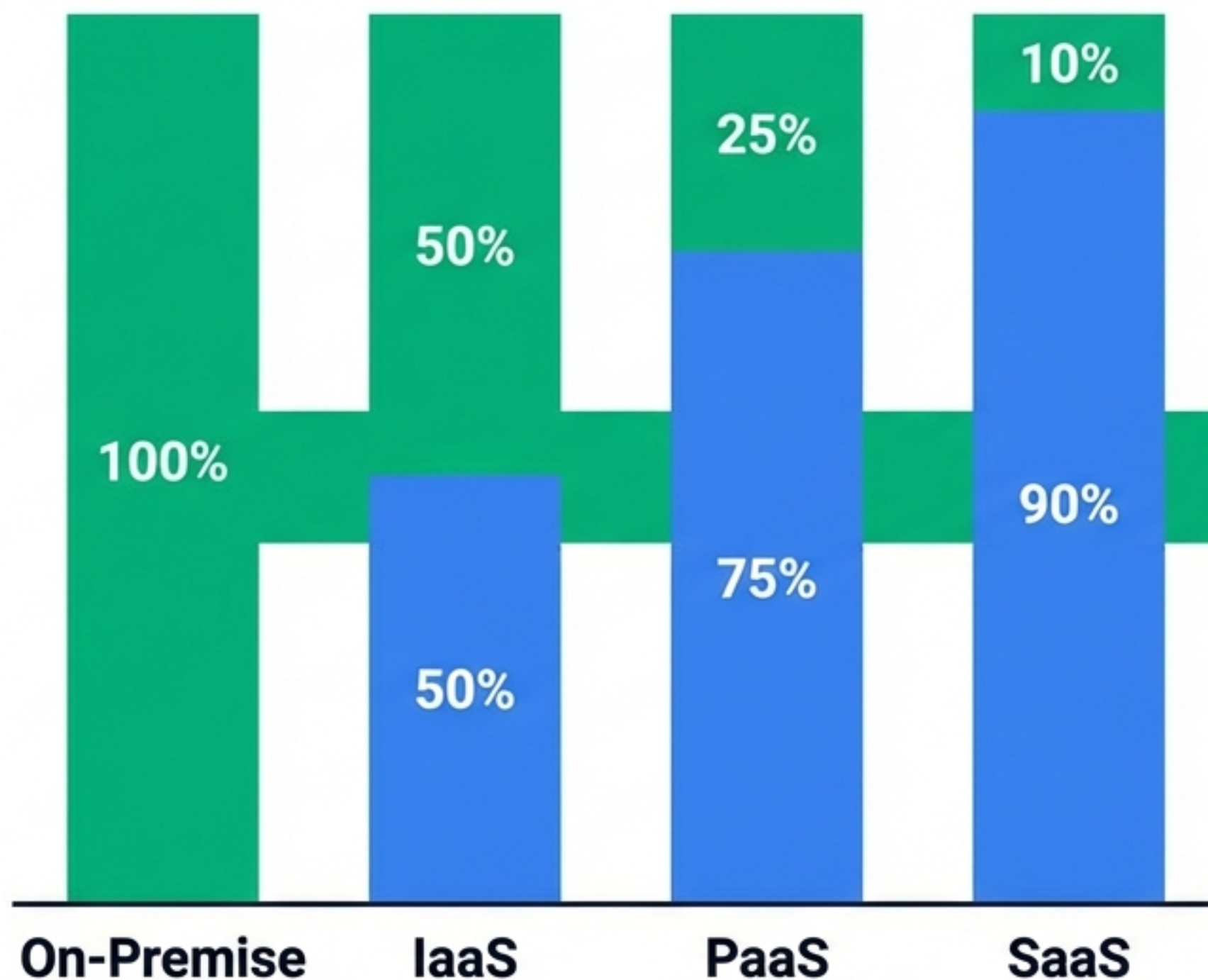
Modelos de Servicio: El Tablero de Juego

A mayor comodidad (SaaS), menor control técnico, pero la responsabilidad sobre los datos permanece inalterable.

IaaS (Infraestructura)	PaaS (Plataforma)	SaaS (Software)
 El cliente gestiona SO, redes, apps. Riesgo principal: Configuración insegura de VMs.	 Proveedor da la plataforma; cliente despliega código. Riesgo principal: Vulnerabilidades en el código o dependencias.	 Proveedor entrega la app completa. Riesgo principal: Gestión de identidades y Shadow IT.

Nota: Cloud Híbrido (Local + Nube) ≠ Multicloud (Múltiples proveedores de nube)

La Regla de Oro: El Modelo de Responsabilidad Compartida



Proveedor (Seguridad DE la nube)

- Infraestructura física
- Red global
- Hardware
- Virtualización

Los datos y la gestión de usuarios son **SIEMPRE** responsabilidad del cliente.

Cliente (Seguridad EN la nube)

- Datos
- Gestión de Accesos (IAM)
- Endpoints
- Configuración

Dimensiones de Seguridad según el ENS

Los 5 pilares para la Administración Pública.

1

Confidencialidad

Prevención de acceso no autorizado.

Ej: Cifrado, MFA

2

Integridad

Garantía de no alteración.

Ej: Hashing, Firma digital

3

Disponibilidad

Continuidad del servicio.

Ej: Redundancia, DRP

4

Autenticidad

Verificación de identidad.

Ej: Certificados digitales

5

Trazabilidad

Capacidad de auditoría.

Ej: Logs, SIEM

El Radar de Amenazas: Riesgos Principales



Configuraciones Erróneas (Top Risk)

Permisos excesivos o buckets públicos por error.



Fuga de Datos (Data Breach)

Exposición masiva de información sensible.



Secuestro de Cuentas

Robo de credenciales y falta de MFA.



Interfaces Inseguras

Vulnerabilidades en APIs públicas.



Vendor Lock-in

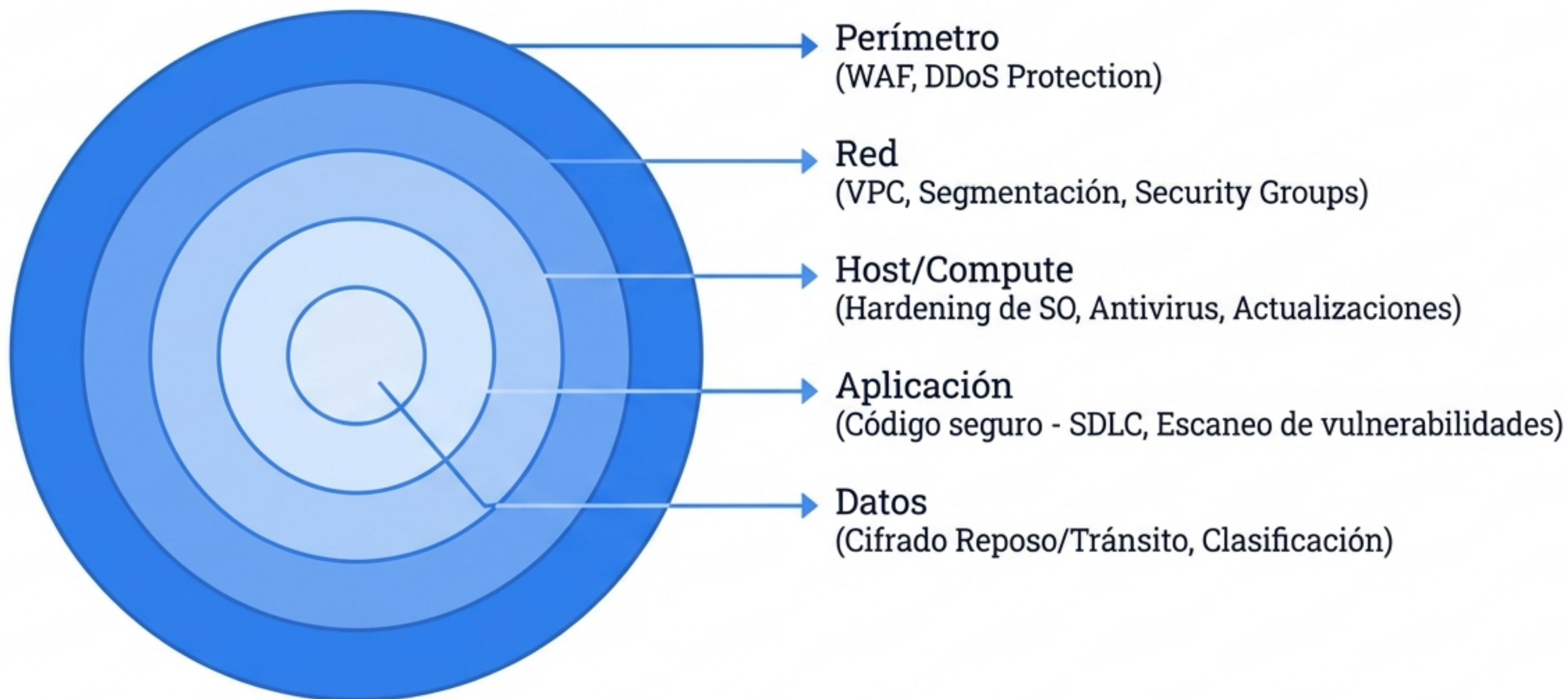
Dependencia tecnológica que dificulta migrar de proveedor.



Riesgo de Cohabitación

Peligros derivados de compartir recursos físicos (multitenencia).

Arquitectura de Defensa en Profundidad



Strategic Concept: Zero Trust Architecture (ZTA) — Nunca confiar, siempre verificar. La ubicación en la red no otorga confianza implícita.

El Arsenal Tecnológico: Herramientas Clave

CASB (Cloud Access Security Broker)

El policía de tráfico. Controla las políticas de acceso entre usuarios y la nube.

CSPM (Cloud Security Posture Management)

El auditor. Detecta errores de configuración en la infraestructura cloud de forma continua.

CWPP (Cloud Workload Protection Platform)

El guardaespaldas. Protege las cargas de trabajo (VMs, Contenedores) dondequiera que corran.

SIEM (Security Information and Event Management)

El cerebro. Centraliza logs y correlaciona eventos para detectar incidentes.

DLP (Data Loss Prevention)

El filtro. Evita que datos sensibles salgan del perímetro corporativo.

Medidas Técnicas y Buenas Prácticas



Protección de Datos

Cifrado obligatorio en tránsito (TLS) y en reposo (AES-256).
Gestión segura de claves (KMS).



Gestión de Identidad (IAM)

Principio de Mínimo Privilegio.
Autenticación Multifactor (MFA) obligatoria.



Resiliencia

Backups automatizados (regla 3-2-1).
Planes de Recuperación ante Desastres (DRP/BCP).



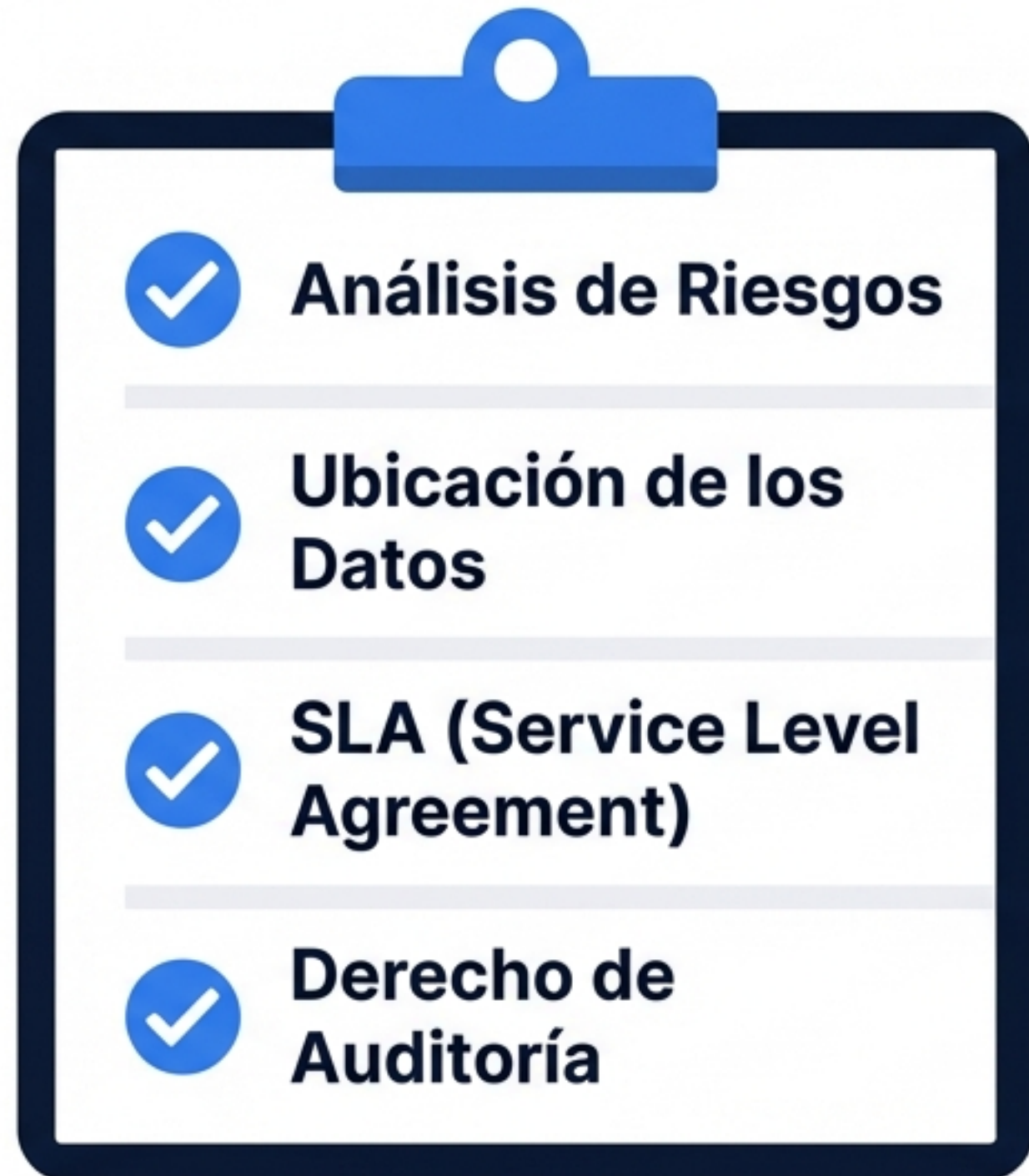
Monitorización

Auditoría continua de logs.
Alertas automatizadas.

Marco Normativo y Gobernanza

Normativa	Ámbito/Descripción
ENS (Esquema Nacional de Seguridad)	Obligatorio para la Administración Pública en España. Clasifica sistemas (Básico, Medio, Alto).
RGPD (Reglamento General de Protección de Datos)	Marco legal UE para datos personales. Exige control sobre la ubicación de los datos.
ISO/IEC 27017	Controles de seguridad específicos para servicios Cloud.
ISO/IEC 27018	Protección de PII (Información de Identificación Personal) en nubes públicas.
ISO/IEC 27001	El estándar base para la Gestión de Seguridad de la Información (SGSI).

Gestión de Riesgos y Proveedores



Identificar activos y amenazas antes de migrar.

¿Están los datos en la UE? Crítico para cumplimiento RGPD.

Definir niveles de servicio, penalizaciones y tiempos de respuesta ante incidentes.

Capacidad de verificar el cumplimiento del proveedor (vía certificaciones como SOC 2 o ISO).

Zona de Peligro: Conceptos Confusos



Error:

PaaS es una mezcla de IaaS y SaaS.



Realidad:

PaaS es un modelo intermedio enfocado en desarrollo, no una mezcla.



Error: Cloud Híbrido es usar AWS y Azure a la vez.



Realidad:

Eso es Multicloud. Híbrido implica conectar infraestructura On-premise con Nube Pública.



Error: En SaaS, yo gestiono las actualizaciones de seguridad.



Realidad: El proveedor gestiona la app; tú gestionas los usuarios.

Zona de Peligro: Mitos de Seguridad

****Mito****



La nube es insegura porque pierdo el control físico.



El proveedor es responsable de mis datos.



Estar en la nube elimina la necesidad de hacer Backups.

****Verdad****



La seguridad depende del contrato y la configuración, no del acceso físico. A menudo, la nube es más segura que un CPD local mal gestionado.



FALSO. El cliente siempre es el Responsable del Tratamiento (Data Controller) ante el RGPD.



La redundancia del proveedor no es un backup. Si borras un dato por error, necesitas tu propia copia.

Resumen Ejecutivo (Cheat Sheet)

Conceptos	Herramientas	Normativa	Responsabilidad
Confidencialidad	CASB (Acceso)	ENS (Admin Pública)	Infraestructura = Proveedor
Integridad	CSPM (Configuración)	ISO 27017 (Cloud Ops)	Datos = Cliente
Disponibilidad	SIEM (Logs)	ISO 27018 (Privacidad)	Configuración = Cliente
Trazabilidad	DLP (Fugas)	RGPD (Datos Personales)	Usuarios = Cliente

Conclusión y Tendencias Futuras

La seguridad en la nube exige una gestión proactiva. No es 'configurar y olvidar'.



SASE

Convergencia de red y seguridad en la nube.



Confidential Computing

Cifrado de datos durante su procesamiento.



IA en Ciberseguridad

Automatización de respuesta ante incidentes.



DevSecOps

Integrar seguridad desde el diseño.

“La seguridad es un camino, no un destino.”